

CSE 331: Computer Security Fundamentals Spring 2026

Ethics, Law, and Policy

Amir Rahmati
Xinrui Yu



Stony Brook Institute
at Anhui University

安徽大学纽约石溪学院

Final Exam: 06/09 19:00 – 21:00

- **From Lecture18-Shellcode to Lecture31-ML Security**
- **In the same format as the midterm exam**
- **There will be original questions from the practice questions/quizzes or their variations**

Background and Context

- **Ethics / Moral Philosophy:** A field that has existed for centuries
- **Computer Security:** Computing in the presence of adversaries
- **Ethical / moral** questions can arise in computer security research (and in industry):
 - When deciding whether or not to pursue a project (research or industry)
 - When deciding on the path(s) for the project (research or industry)
 - When deciding on the path(s) for disclosing vulnerabilities to impacted stakeholders and the public (research or industry)
 - When deciding how much time and money to invest in patching a product (industry)
 - And more

Examples of Ethical Thought Manifesting in the Computer Security Research Community

- The Menlo Report presents ethical principles for information and communication technology research (2012)
- Conference Calls for Papers discuss ethics
- Conference Ethics Review Committees evaluate paper submissions
- Paper submissions and publications discuss ethics

Principles in the 2012 Menlo Report

- **Respect for Persons:** Participation as a research subject is voluntary, and follows from informed consent; Treat individuals as autonomous agents and respect their right to determine their own best interests; Respect individuals who are not targets of research yet are impacted; Individuals with diminished autonomy, who are incapable of deciding for themselves, are entitled to protection
- **Beneficence:** Do not harm; Maximize probable benefits and minimize probable harms; Systematically assess both risk of harm and benefit
- **Justice:** Each person deserves equal consideration in how to be treated, and the benefits of research should be fairly distributed according to individual need, effort, societal contribution, and merit; Selection of subjects should be fair, and burdens should be allocated equitably across impacted subjects
- **Respect for Law and Public Interest:** Engage in legal due diligence; Be transparent in methods and results; Be accountable for actions
- Available at: https://www.dhs.gov/sites/default/files/publications/CSD-MenloPrinciplesCORE-20120803_1.pdf

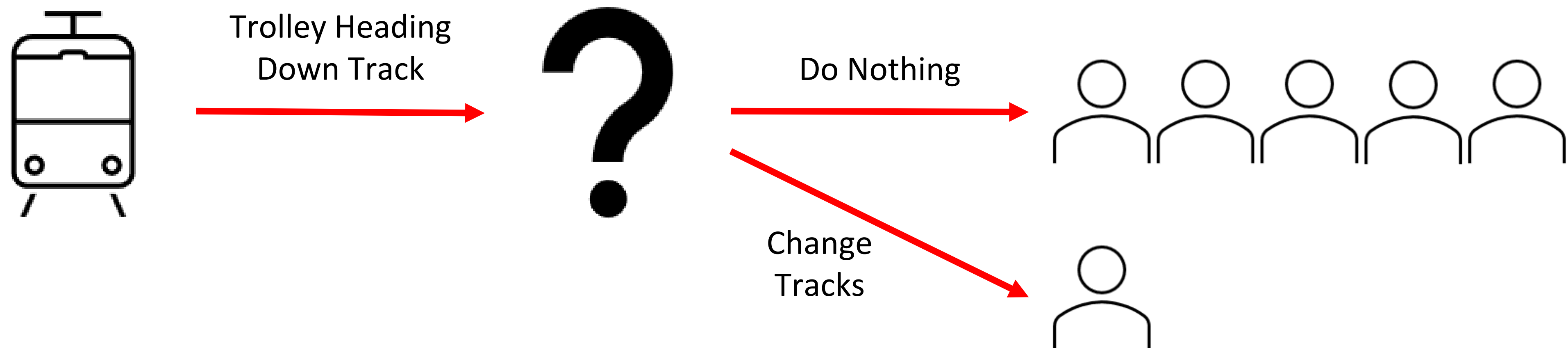
Making Ethical Decisions

- **Often** though not always the field is making good / **morally right decisions**
- **Often** though not always there is general **agreement** on what constitutes a good / morally right decision
- But **what should we**, as a field, do **if there is disagreement or uncertainty** on what is good / morally right?

Example Decision-Making Process

- **Step 1:** Apply **known methods** for ethical evaluation; e.g., within the security research community, apply the principles in the Menlo Report
- **Step 2:** **When** what constitutes a good / **morally right** decision is **not obvious: clearly, precisely, and thoughtfully explore and articulate arguments** for and against different decisions
- **Throughout:** Be aware that **there exist different approaches** (ethical frameworks) for making moral decisions and that different approaches can in some cases come to **different conclusions**

A Classic Dilemma: The Trolley Problem



The Trolley Problem is a classic thought experiment / ethical dilemma (Philippa Foot).

A runaway trolley with no brakes is heading straight. **Five people** are tied to those tracks. **One person** is tied to an alternate set of tracks.

Should the operator do nothing (five people die) **or change the path** of the trolley (one person dies)?

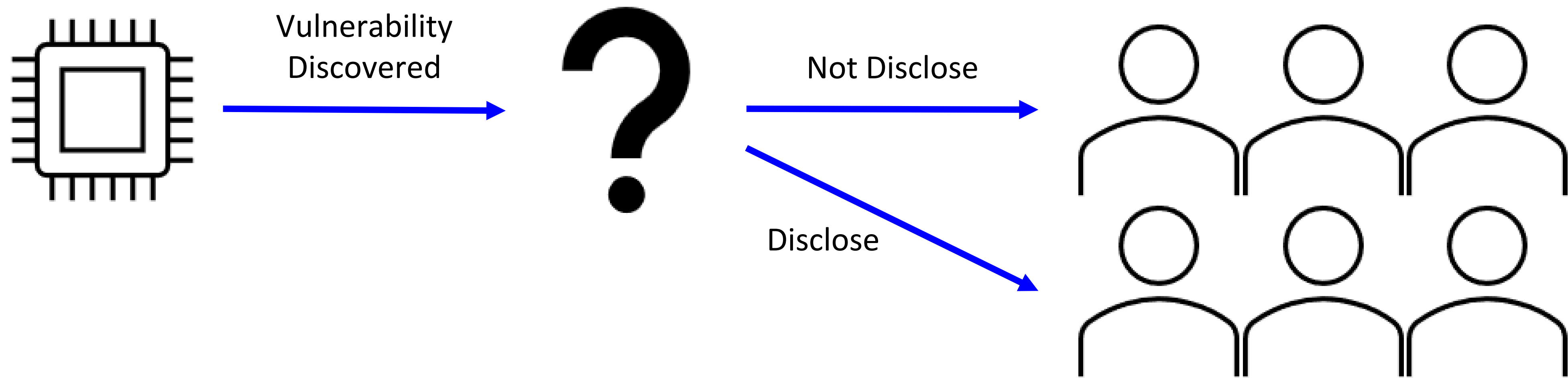
Scenario A: Medical Device Vulnerability

(some details may not reflect reality)

- **Company A** produces a **lifesaving wireless implantable medical device**. It is the only device of its type on the market. When a patient receives this device, it will (on average) **extend their lifespan by 10 years**
- Company A goes **bankrupt** because the condition is rare and not many people use the device. However, there are many devices still available (already produced), **many devices are already implanted** in patients, and **doctors still implant** the (now unsupported) device in new patients that need it
- Later, **researchers discover a software vulnerability** in the device. **If exploited**, the vulnerability could cause **significant harm** to the patients. Since Company A no longer exists, the **software cannot be updated** to address this vulnerability
- The **likelihood** of security **compromise** is **zero** (regardless of whether disclosed or not)
- ***Question:** What should the researchers do? Disclose the vulnerability to the public? Not disclose the vulnerability to anyone? Talk with the FDA?*

Scenario A: Medical Device Vulnerability

(some details may not reflect reality)



- **If not disclose:** **Patients** have **no awareness** that their device is vulnerable; **patients** keep and/or proceed with obtaining device and **receive** significant **health benefits**
- **If disclose:** **Patients** have the **choice** to not receive or to remove the device; **risk** of **psychological harm** if **patients know** they have a **vulnerable device** (even if chance of exploitation is zero); **risk of health harm** if patients do not receive / remove the device

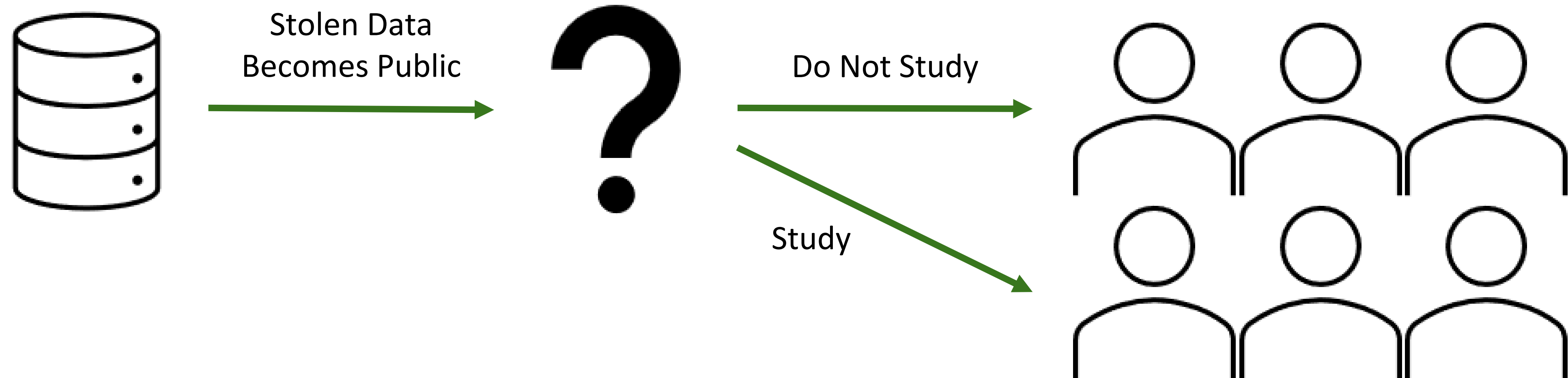
Scenario B: Studying Stolen Data

(some details may not reflect reality)

- **Company B matches employers** (jobs) with **job applicants**; the company is **growing rapidly** and will have 100x more job applicants in five years
- Job **application packets** are **confidential**, as are some job-specific questions
- Company B's **AI job-to-applicant matching system** is **suspected** to have **racial** and **gender biases**
- Company B is **compromised** and the entirety of their **data** (all past jobs, all past application packets, internal ML model) is **stolen**
- **Researchers wish to study** the **stolen data**, to scientifically **measure** racial and gender **biases** and, if biases are found, **measure** the **impacts** of biases on **past job applicants**
- The **researchers** also wish to study the data and **assess** whether the **AI** system is **vulnerable** to adversarial manipulation, which could also negatively impact future job applicants
- The **researchers plan** to propose **technical** and **policy mechanisms** to **mitigate** any issues (e.g., biases, vulnerabilities) that they uncover; removing biases means that **more people** will be **connected with jobs** (for our analysis, we assume that removing biases does not make it harder for other people to get jobs)
- Many **job applicants** have publicly **stated** a **desire** that the **stolen data** be **permanently erased**, everywhere
- The **researchers obtained** a copy of the **data** while still publicly available and, if they study the data, **must retain** a copy for use in results validation in case their results are challenged (e.g., challenged by Company B)
- ***Question:** Should the researchers study this data?*

Scenario B: Immorally-Obtained Data

(some details may not reflect reality)



- **If not studied:** The **stolen data** is from **people**; in choosing this option, the researchers **would not have further violated** their **privacy** and their right to **informed consent**
- **If studied:** Result will help **prevent future job applicants** from **being harmed by biased or a vulnerable job-to-applicant AI matching system**

Scenario C: Inadvertent “Disclosure”

(some details may not reflect reality)

- A **research paper** is **submitted** to a top peer-reviewed conference; the paper details the **discovery** of a **previously undisclosed vulnerability** in the product from **Company C**
- The authors write in their paper that they will **soon disclose** to Company C
- The authors **do not want to disclose** to Company C until **after** the paper has been officially **accepted**
- A **person** from **Company C** is on the **program committee**
- The program committee chairs required **all program committee members** to **explicitly agree** to maintain the **confidentiality of submissions** and not discuss them outside of the program committee; Company C **agreed** that the employee could agree to this program committee membership requirement
- That **person** (not necessarily a reviewer) reads the paper and realizes that the **vulnerability** can lead to **serious harms** if exploited
- ***Question: What should the person from Company C do? Disclose the vulnerability internally? Search to see if it is actively being exploited? Wait until the paper is accepted? What should they do if the paper is rejected? Does the answer change if they were asked to be a reviewer? Should they be asked to review the paper? Should they be allowed to review it?***

Scenario C: Inadvertent “Disclosure”

(some details may not reflect reality)



- **If not reported:** Confidentiality of PC process preserved; authors have agency over when and how they disclose
- **If reported:** Company C checks to see if the vulnerability is already being exploited; Company C can immediately begin working on solutions to protect their users; users' security, privacy, and safety will be protected before the vulnerability becomes public

Summary of Three Scenarios

- **Scenario A:** Researchers find a **vulnerability** in a **medical device**; device manufacturer goes out of business. Should the researcher disclose the vulnerability to doctors, patients, and the public?
- **Scenario B:** Adversaries **stole data** from a job-applicant matching service. Should researchers study that data if doing so could significantly benefit other people?
- **Scenario C:** Researchers submit a paper with an undisclosed vulnerability in the product from Company C to a conference. An **employee** at **Company C** is **on the conference program committee**. Should the employee disclose the vulnerability to their company?

Consequentialist Ethics

- Focuses on **consequences** of actions, policies, institutions
- **Utilitarianism**: example of consequentialism in which consequences are measured with respect to well-being
- Different instances of utilitarianism take different definitions for well-being:
 - **Hedonic utilitarianism**: Actions are morally right if they promote the **greatest happiness** for the **greatest number of people**
 - **Objective list utilitarianism**: Actions are morally right if they promote the **greatest benefits** from an **objective list** for the **greatest number of people** (e.g., health, wealth, access to resources)
- Consequentialists **count numbers** and **weigh benefits / harms**, e.g., five deaths are worse than one → **change the trolley's tracks**

Deontological Ethics

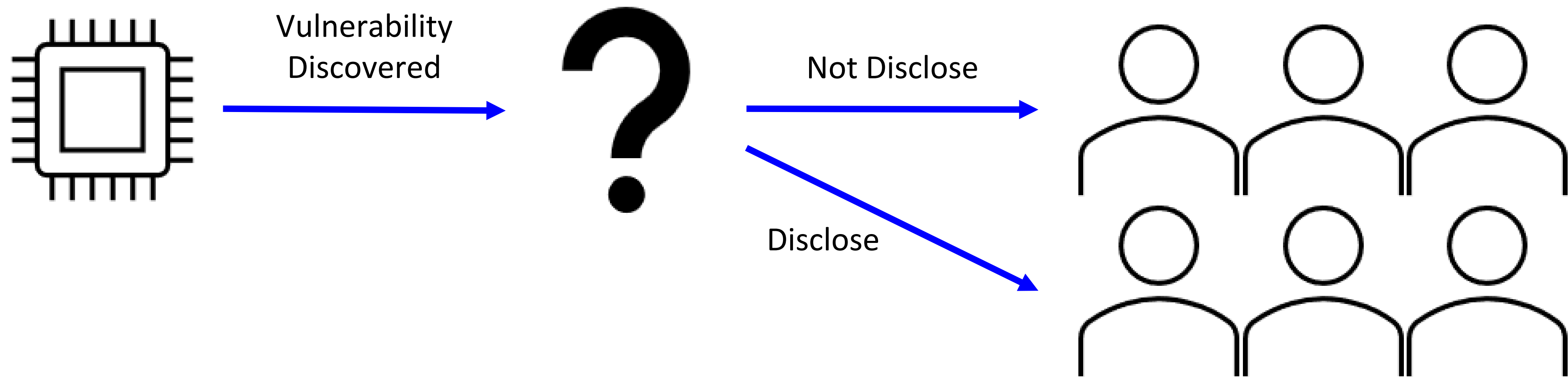
- **Deontological** ethics focuses on the moral **duties** of a moral **actor**, e.g., an individual or institution
- **People** have **fundamental rights**; moral **actors** have a **duty** to **respect** those **rights**
- Example rights: The **right** to **privacy**, the right to **self-agency**, the right to **informed consent**
- **Kantian deontological ethics**: One should **not violate any single person's rights in order to accomplish another objective**; Kant in describing this “Categorical Imperative”: human beings should be treated as “ends and never purely as means”
- **Changing the trolley tracks** would **violate one person's right** (their right to live) **in order to accomplish** the **saving of five other** lives; changing the track would **use** that **single person** as an “**means**”, **not** as an “**ends**”; under Kantian deontological ethics → **do not change the trolley's tracks**

Framework Limitations

- Modern **ethicists** often do **not** use a **single framework** (recall the existing presence of consequentialist and deontological ethics in elements of the computer security community's approach to ethics, e.g., the Menlo Report)
- **Consequentialist** and **deontological** ethics both have **limitations**. As a result, they are often not so clearly distinct in their answers as this deck makes it look like.
- The goal of this discussion is **not** to **encourage** the **adoption** of consequentialist or deontological ethics
- Rather, the **goal** is to explore how **different frameworks** can come to **different conclusions** of what is good / **morally right**

Scenario A: Medical Device Vulnerability

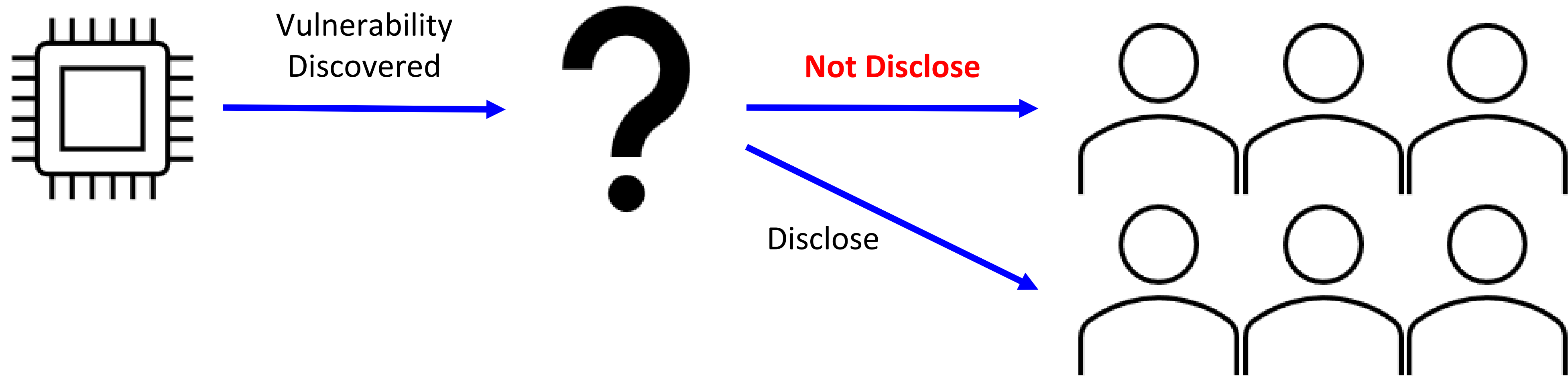
(some details may not reflect reality)



Scenario A: Researchers find a **vulnerability** in a **medical device**; device manufacturer is out of business. Should the researcher disclose the vulnerability to doctors, patients, and the public? Should the researchers keep the vulnerability secret?

Frameworks & Medical Device Vulnerability

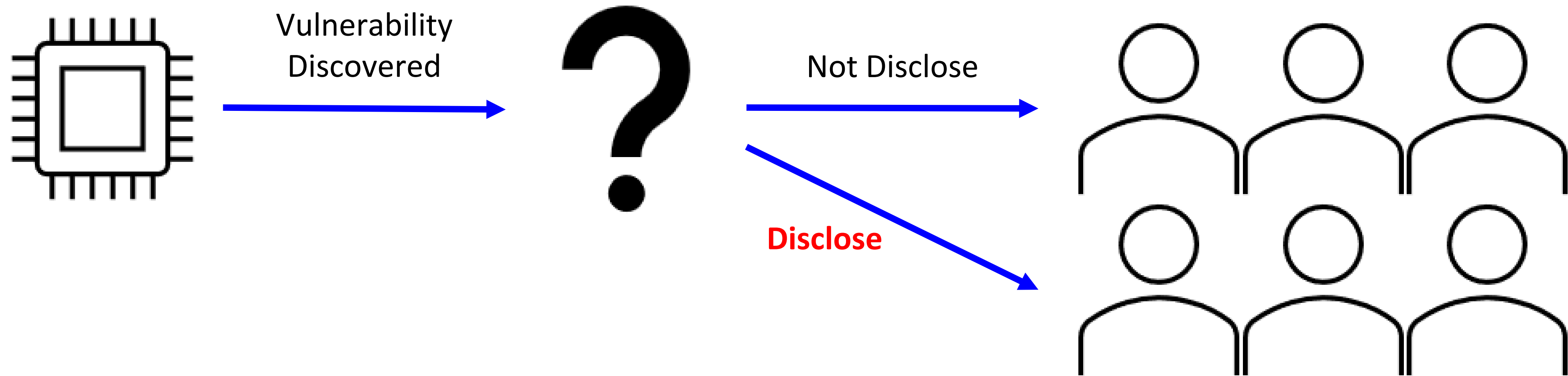
(some details may not reflect reality)



Consequentialist Ethics: Likelihood of exploit is zero; harms if patients informed (health: remove device / not get device; happiness: live with knowledge that the device has faults) → **do not disclose vulnerability**

Frameworks & Medical Device Vulnerability

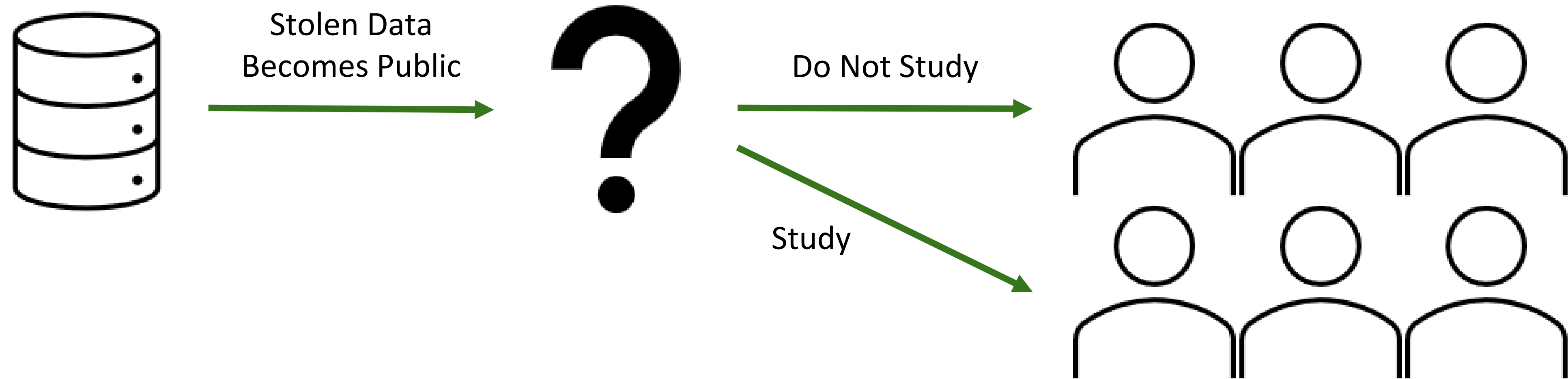
(some details may not reflect reality)



Deontological Ethics: Duty to respect people's **right to informed consent** (e.g., warnings on medicine ads) and right to **self-agency** (make their own decisions about what is best for them) → **disclose vulnerability**

Scenario B: Immorally-Obtained Data

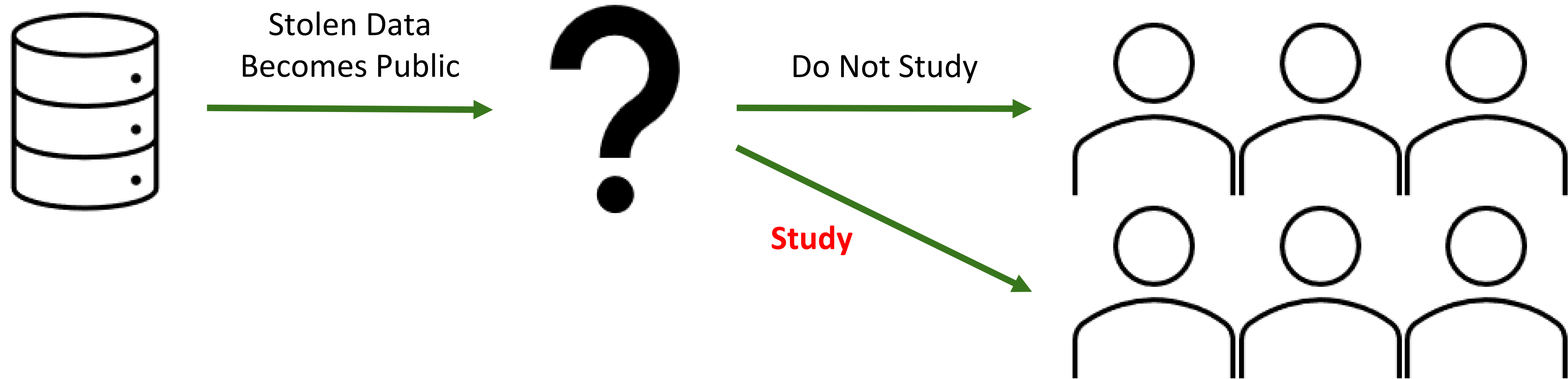
(some details may not reflect reality)



Scenario B: Adversaries **stole data** from a job-to-applicant matching system, which includes significant private information about job applicants. Should researchers study that data if doing so can benefit future job applications (e.g., decrease future racial and gender biases and the risk of manipulation in the job-to-applicant matching AI)?

Frameworks & Immorally-Obtained Data

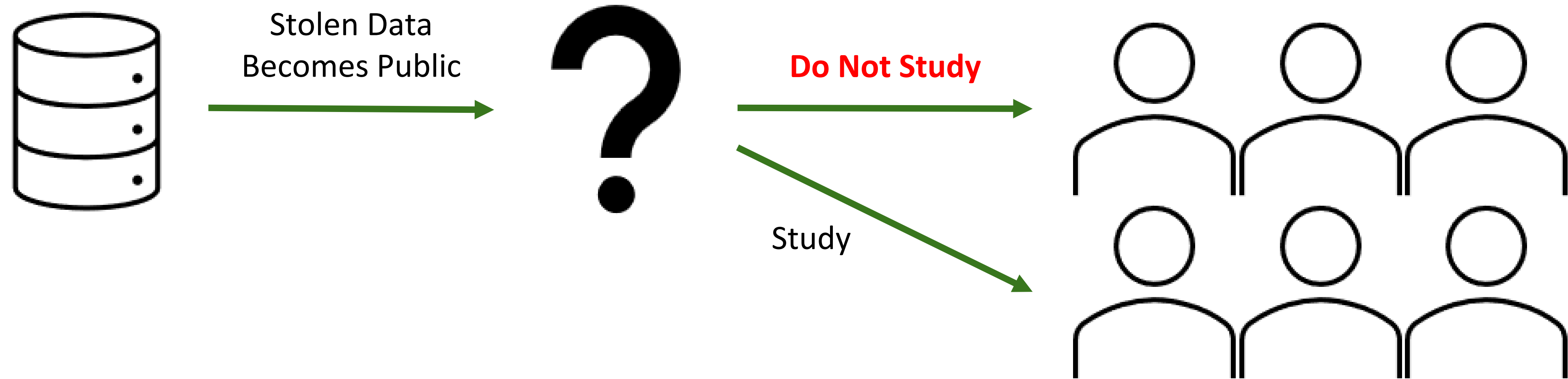
(some details may not reflect reality)



Consequentialist Ethics: **Benefits** of studying the data to society and to future job applicants is **high**; the data was already made “public”, which itself caused harms, but the study of the data does not create new harms → **study the data**

Frameworks & Immorally-Obtained Data

(some details may not reflect reality)



Deontological Ethics: People have a **right** to **privacy** and **informed consent**; **rights extend** to data **intended** to be private even if researchers have access; impacted job applicants **explicitly requested** the **data** to be **deleted**; while studying data could improve the rights of future job applicants, doing so would be **at the expense** of the **rights of those impacted by the data breach** → **do not study the data**

Scenario C: Inadvertent “Disclosure”

(some details may not reflect reality)



Scenario C: Researchers submit a paper with an undisclosed vulnerability in the product from Company C to a peer-reviewed conference. An **employee** at **Company C** is **on the conference program committee**. Should the employee disclose the vulnerability to their company?

Frameworks & Inadvertent “Disclosure”

(some details may not reflect reality)



Consequentialist Ethics: Possible **harms** to **authors** if employee of Company C **discloses vulnerability** to Company C; significant **benefits** to Company C’s **users** if the employee **discloses vulnerability** to Company C; the **benefits / harms** must be weighed → Employee of Company C **should report** the vulnerability to Company C

Frameworks & Inadvertent “Disclosure”

(some details may not reflect reality)



Deontological Ethics: The program committee member may feel a sense of **duty** to **Company C** and their **users**; program committee members also have duty to respect the **autonomy** of **authors** and the **confidentiality** of the **peer review process**; the employee **agreed** to **respect this duty** when they joined the program committee, as did Company C’s leadership team; **if breaking** the **confidentiality** of the peer review process is allowed, the whole institution of the **peer review process** would **not be possible** → Company C employee **should not report** the vulnerability to Company C

No right/wrong answers

Overarching principles/lessons

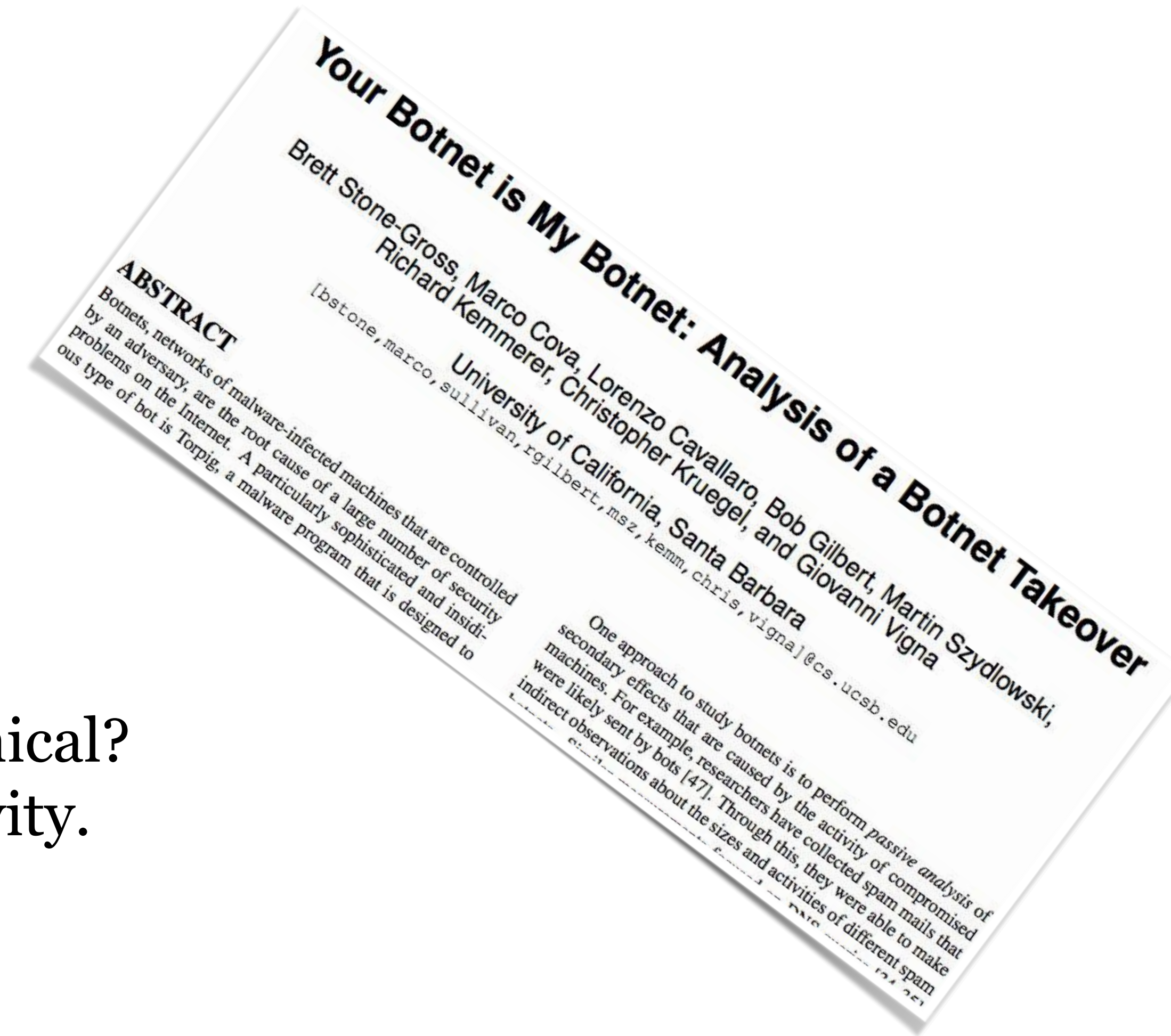
- Ethics: Try to be a good person. Be thoughtful about your actions and their effects on yourself and others.
- Legal issues: Don't violate laws.
- If lawyers or law enforcement are involved, you have already lost. It doesn't matter if you could, in theory, win the case in the end.

Legal/ethical principle: Property rights

- Respect other people's property.
- Example: Hacking your own password.
 - On your own machine: Probably ok. (Possible exception: DMCA.)
 - On someone else's machine: Get permission or else it's probably not ok.

Ethical Principle: Minimizing harm

- Example: Botherding (taking over a botnet)
- Is this ethical or not?
 - Interfering with a legal botnet is definitely illegal.
- Is taking over a botnet for research purposes ethical?
It is pursuing illegal activity to study illegal activity.
- What is harm minimization?



Personal and Privacy Rights

- Principle: Informed consent
 - Human subjects research should go through ethical review
 - Some companies now have review processes (Example: Facebook happiness research)
 - Human subjects research includes any collection of Personally Identifiable Information

Judge Confirms Government Paid CMU Scientists to Hack Tor Users for FBI

📅 February 25, 2016 👤 Swati Khandelwal



Everything is now crystal clear:

The security researchers from Carnegie Mellon University (CMU) were hired by the federal officials to discover a technique that could help the FBI [Unmask Tor users](#) and **Reveal their IP addresses** as part of a criminal investigation.

Yes, a federal judge in Washington has recently confirmed that the computer scientists at CMU's Software Engineering Institute (SEI) were indeed behind a hack of the TOR project in 2014, according to court documents [\[PDF\]](#) filed Tuesday.

In November 2015, The Hacker News reported that Tor Project Director *Roger Dingledine* accused the Federal Bureau of Investigation (FBI) of paying the CMU, at least, [\\$1 Million for providing information](#) that led to the criminal suspects identification on the [Dark Web](#).

After this news had broken, the [FBI denied the claims](#), saying *"The allegation that we paid [CMU] \$1 Million to hack into TOR is inaccurate."*

Informed consent

- Example: Jason Fortuny posted fake sex ad on Craigslist as a woman in 2006
- Received hundreds of replies, posted them all online
- Unethical? Yes.
- Illegal? Unclear.

Wiretapping

18 U.S. Code § 2511 - Interception and disclosure of wire, oral, or electronic communications prohibited

Current through Pub. L. [113-296](#), except [113-287](#), [113-291](#), [113-295](#). (See [Public Laws for the current Congress](#).)

US Code

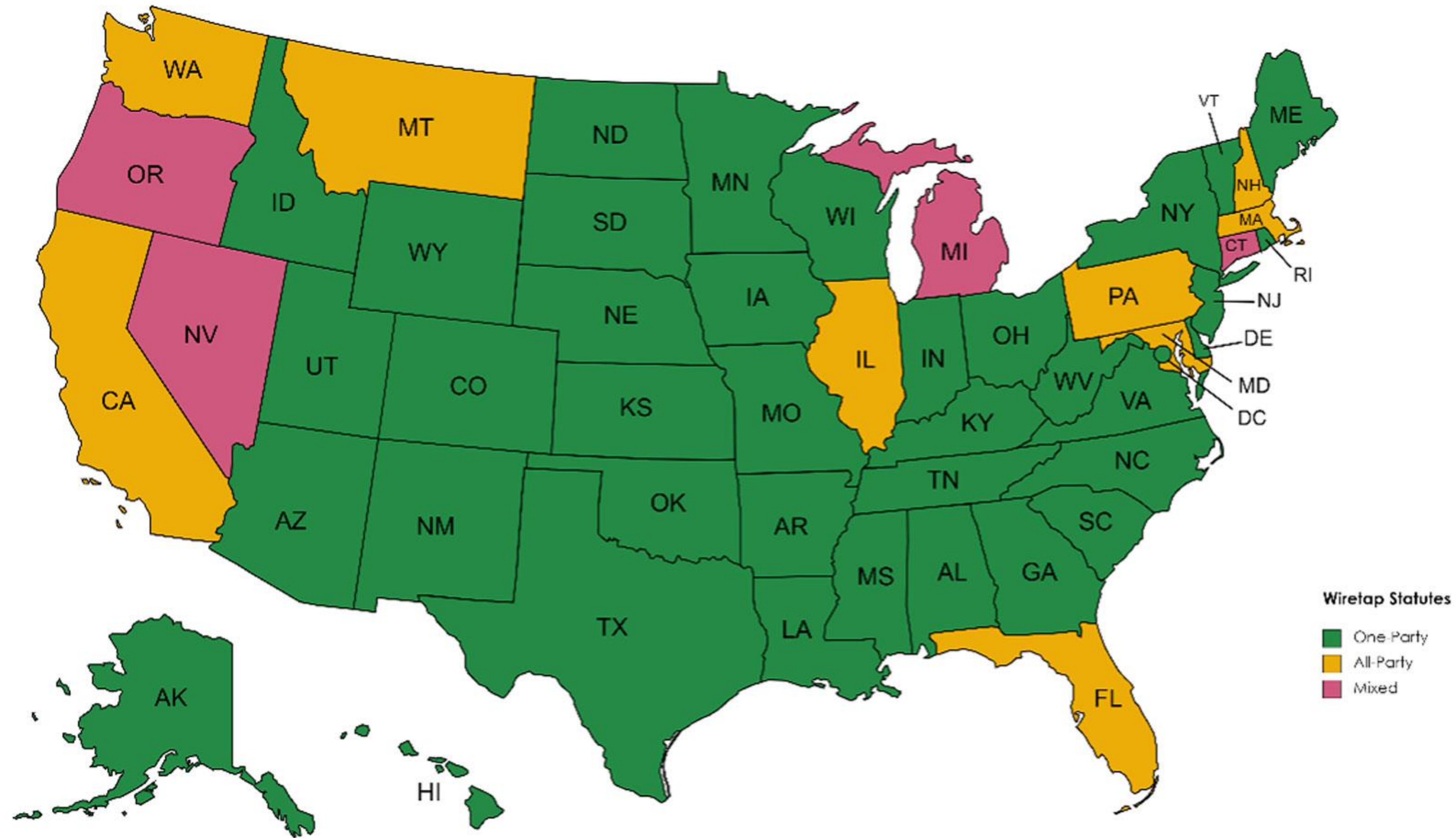
Notes

[prev](#) | [next](#)

- (1)** Except as otherwise specifically provided in this chapter any person who—
- (a)** intentionally intercepts, endeavors to intercept, or procures any other person to intercept or endeavor to intercept, any wire, oral, or electronic communication;
 - (b)** intentionally uses, endeavors to use, or procures any other person to use or endeavor to use any electronic, mechanical, or other device to intercept any oral communication when—
 - (i)** such device is affixed to, or otherwise transmits a signal through, a wire, cable, or other like connection used in wire communication; or
 - (ii)** such device transmits communications by radio, or interferes with the transmission of such communication; or
 - (iii)** such person knows, or has reason to know, that such device or any component thereof has been sent through the mail or transported in interstate or foreign commerce; or
 - (iv)** such use or endeavor to use (A) takes place on the premises of any business or other commercial establishment the operations of which affect interstate or foreign commerce; or (B) obtains or is for the purpose of obtaining information relating to the operations of any business or other commercial establishment the operations of which affect interstate or foreign commerce; or

- New York is a “one-party consent” state. one party in a conversation must consent for it to be recorded.

Wiretapping Map of the US



FISA background

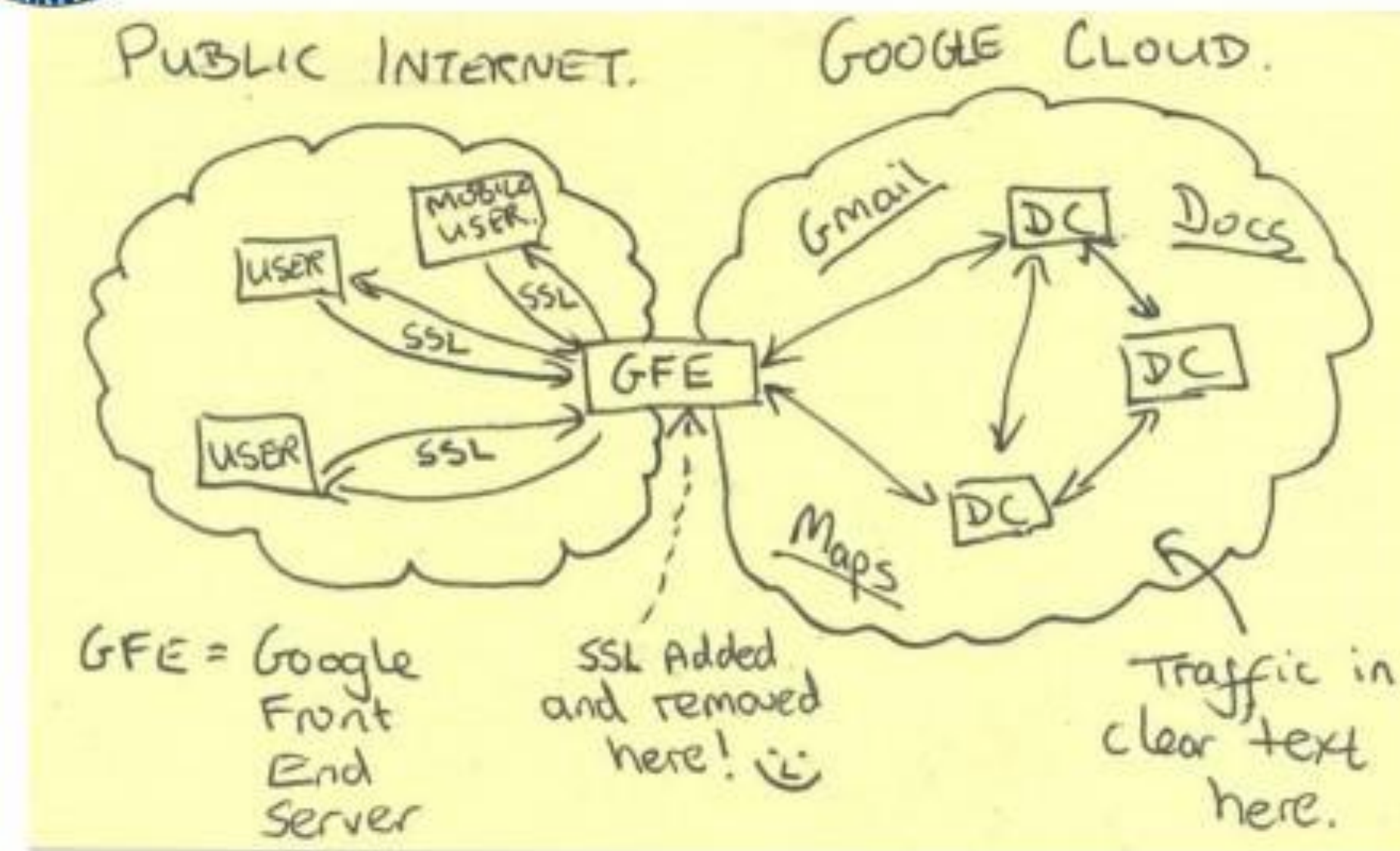
- 1978 Foreign Intelligence Surveillance Act
 - Passed in response to Church Committee investigation of COINTELPRO scandals
 - Codified separation between domestic law enforcement activities and international intelligence activities
 - FISA Court was established to handle surveillance warrants for intelligence investigations in the US
- After 2001, PATRIOT Act weakened some of these separations.

October 2013: MUSCULAR

TOP SECRET//SI//NOFORN



Current Efforts - Google



TOP SECRET//SI//NOFORN

- Official Google statement: “We are outraged”

Key Escrow and Law Enforcement Backdoors Redux

Recently, the head of the National Security Agency provided a rare hint of what some U.S. officials think might be a technical solution. Why not, suggested Adm. Michael S. Rogers, require technology companies to create a digital key that could open any smartphone or other locked device to obtain text messages or photos, but divide the key into pieces so that no one person or agency alone could decide to use it?

“I don’t want a back door,” Rogers, the director of the nation’s top electronic spy agency, said during a speech at Princeton University, using a tech industry term for covert measures to bypass device security. “I want a front door. And I want the front door to have multiple locks. Big locks.”

Law Enforcement Access Policy

- Policy/ethics question: Is it preferable to have law enforcement/intelligence:
 - Stockpile software vulnerabilities, write targeted malware, and hack into targets when desired
 - Mandate encryption backdoors or otherwise enable mass surveillance

Disclosure options for security flaws

- Develop fully weaponized malware and distribute on black market
- Tell no one
- Sell vulnerability to middleman and don't report to vendor
- Report to vendor only
- Report to vendor and receive bug bounty
- Report to vendor, wait for fix, report to public (“responsible disclosure”)
- Report in full to public immediately (“full disclosure”)

The process of reporting vulnerabilities

- Some vendors have a sensible reporting process
 - E.g., Firefox and Chrome teams respond and react quickly, easy to work with on fixing bugs, etc.
- Some vendors less so
 - E.g., Send email through an intermediary, receive ACK, no real conversation.
 - E.g., Send email, poke individual folks for replies, no replies. Give up.
- Some vendors are playing catch-up
- Some vendors are the worst: they will try to gag/sue you

Policy questions around security research

- Should exploit sales be legal?
 - Code as speech principle says yes
 - Is publishing exploits ethical?
- How about mixed-use tools?
 - Privacy tools like Tor or encrypted messengers used by criminals, normal people, activists

Summary

- Try to behave ethically.
- Try not to break the law.
- Be informed about policy.